

Divulgación de Ubicación Basada en Navegador: Simulación Controlada con Enlace Seeker



Alcance	Simulación controlada usando un teléfono del investigador actuando como dispositivo víctima; uso educativo y analítico solamente.
Entorno	Kali Linux, Seeker, túnel temporal, navegador móvil y teléfono Android del investigador.
Evidencia principal	Capturas de Seeker, túnel temporal, listener, permiso de ubicación móvil y terminal redactada.

Uso educativo y analítico solamente. URL pública, IP, dispositivo y ubicación fueron redactados.

Introducción

Los navegadores móviles piden permisos sensibles durante actividades comunes, especialmente cuando un sitio afirma que necesita ubicación para personalizar la experiencia. Este riesgo es distinto al phishing o a una aplicación maliciosa: el usuario no tiene que instalar software ni escribir una contraseña. La decisión ocurre en el permiso del navegador.

Este estudio de caso examina una simulación controlada con Seeker usando un túnel temporal y un teléfono del investigador actuando como dispositivo víctima. El objetivo fue documentar cómo se veía la página, cómo el navegador presentó la solicitud de ubicación, qué datos aparecieron después de conceder permiso y por qué esto importa fuera del laboratorio.

Metodología

La simulación se realizó en un laboratorio controlado usando Kali Linux, Seeker, un túnel temporal y un navegador móvil en un teléfono Android propiedad del investigador. El alcance se limitó a infraestructura propia, enlace de prueba temporal e interacción consentida. No hubo víctimas reales, dispositivos de terceros, cuentas de producción ni rastreo no autorizado.

1. Resumen

Seeker puede usarse como herramienta defensiva de enseñanza porque muestra cómo una página web puede pedir acceso a ubicación y registrar datos del dispositivo o navegador cuando el usuario concede permiso. En este escenario, la pregunta era si una página creíble con tema de ubicación podía producir datos observables desde un teléfono que aceptó el permiso.

2. Preparación del caso

El equipo de laboratorio inició el entorno de Seeker y seleccionó una plantilla con tema de ubicación. Luego se usó un túnel temporal para hacer que la página local fuera accesible desde el teléfono. Lo importante no fue la secuencia exacta, sino la transición de una página local a un enlace público que un navegador móvil podía abrir.

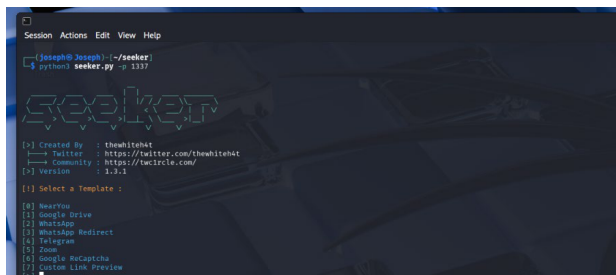


Figura 1. Entorno de lanzamiento de Seeker en el equipo de laboratorio, mostrando la etapa de selección de plantilla usada para la simulación controlada.

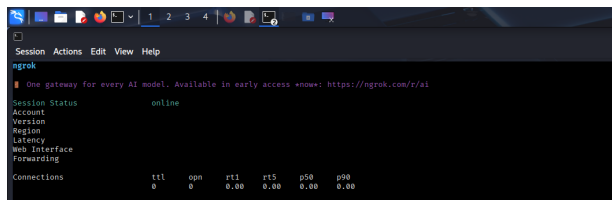


Figura 2. Sesión de túnel temporal usada para exponer la página de prueba local mediante una ruta pública, con URL y datos de cuenta redactados.

3. Enlace público y permiso

Después de preparar el enlace público de prueba, el teléfono abrió la página con tema de ubicación como dispositivo simulado. La actividad de solicitud apareció en la sesión del túnel después de visitar la página. El navegador móvil mostró una solicitud de permiso de ubicación para el sitio. Este fue el punto de decisión: la exposición dependió de que el usuario concediera acceso, no de un bypass invisible del modelo de permisos del navegador.

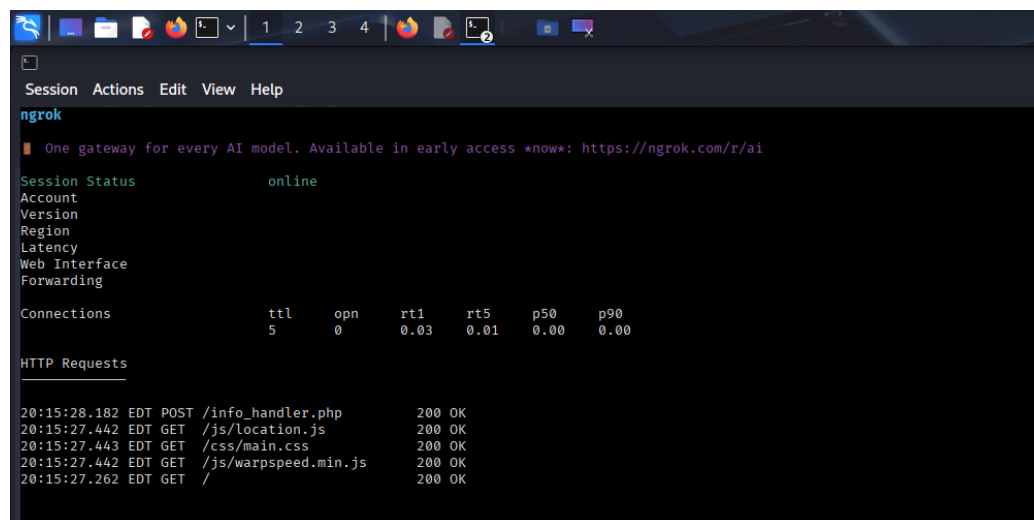


Figura 3. Vista del listener del túnel mostrando solicitudes web del teléfono después de abrir el enlace público, con detalles de reenvío redactados.

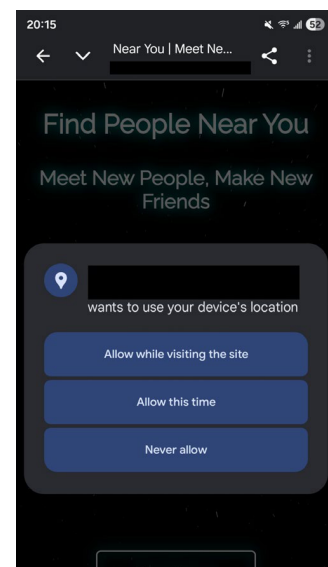


Figura 4. Teléfono del investigador actuando como dispositivo víctima, abriendo el enlace y recibiendo una solicitud de permiso de ubicación del navegador móvil. URL pública redactada.

4. Evidencia recopilada

Después de conceder el permiso, la terminal registró campos relacionados con dispositivo, navegador, red y ubicación. El punto evidenciario más importante fue que el permiso del navegador creó una puerta de consentimiento: una vez aprobado, el contexto sensible regresó a la página y se hizo visible en la terminal de recolección. Las redacciones conservaron el valor analítico del artefacto sin exponer URL, IP ni datos de ubicación reales.

```
[Joseph@Joseph] (~)/seeker]
$ python3 seeker.py -p 1337
```



```
Created By : thewhitehat
Twitter    : https://twitter.com/thewhitehatsec
Community  : https://t.me/thewhitehatsec
Version    : 1.3.1

[!] Select a Template :
```

[0]	NearYou	./src/handler/nearyou.php	100 OK
[1]	Google Drive	./src/handler/google-drive.php	200 OK
[2]	WhatsApp	./src/handler/whatsapp.php	200 OK
[3]	WhatsApp Redirect	./src/handler/whatsapp-redirect.php	200 OK
[4]	Telegram	./src/handler/telegram.php	200 OK
[5]	Zoom	./src/handler/zoom.php	200 OK
[6]	Google ReCaptcha	./src/handler/google-recaptcha.php	200 OK
[7]	Custom Link Preview	./src/handler/custom-link-preview.php	200 OK
>	0	./src/handler/placeholder-image.php	200 OK
	1	./src/handler/placeholder-video.php	200 OK

```
[+] Loading NearYou Template ...
[+] Port : 1337

[+] Starting PHP Server... [ ✖ ]
[!] Old instance of php server found, restarting...
[+] Starting PHP Server... [ ✔ ]

[+] Waiting for Client... [ctrl+c to exit]

[!] Device Information :
```

[+]	OS	: Android 10
[+]	Platform	: Linux armv8l
[+]	CPU Cores	: 8
[+]	RAM	: 8
[+]	GPU Vendor	: Qualcomm
[+]	GPU	: Adreno (TM) 740
[+]	Resolution	: 384x824
[+]	Browser	:
[+]	Public IP	:

```
[!] IP Information :
```

[+]	Continent	:
[+]	Country	:
[+]	Region	:
[+]	City	:
[+]	Org	:
[+]	ISP	:

```
[!] Location Information :
```

[+]	Latitude	:
[+]	Longitude	:
[+]	Accuracy	:
[+]	Altitude	:
[+]	Direction	:
[+]	Speed	:

[+]	Google Maps	:
[+]	Data Saved	:

```
[+] Waiting for Client...
```

Figura 5. Captura redactada de la terminal de Seeker mostrando campos de dispositivo, navegador, red y ubicación después de conceder el permiso.

5. Por qué ocurrió la divulgación

La divulgación ocurrió porque el sitio pidió un permiso que los navegadores permiten y el usuario lo aprobó. No fue un compromiso silencioso del sistema operativo. Fue una exposición basada en consentimiento creada por un pretexto creíble, un enlace público y una solicitud de permiso que parecía rutinaria.

El tema “cerca de ti” hacía que el permiso pareciera apropiado. Aunque el navegador mostró el origen del sitio, muchas personas se enfocan en el mensaje y en el botón de permitir, no en verificar el dominio temporal. El túnel convirtió una página local en una página pública alcanzable desde el teléfono, lo que permitió la interacción fuera del contexto localhost.

6. Impacto real para el individuo

Conceder ubicación a una página engañosa puede revelar dónde vive, trabaja, estudia o pasa tiempo una persona. Si se combina con IP pública, tipo de dispositivo, navegador y proveedor de red, puede apoyar phishing dirigido, acoso, doxxing, seguimiento o intentos de ingeniería social más personalizados.

El riesgo es serio en teléfonos porque las personas tratan muchos permisos como rutinarios y pueden aprobarlos mientras están distraídas. Incluso si la página no instala malware, los datos recopilados pueden ayudar a crear un perfil de la persona, coordinar mensajes futuros o diseñar un señuelo más creíble.

7. Mitigación y prevención

La defensa práctica es reducir permisos de ubicación innecesarios. Los usuarios deben negar solicitudes de ubicación de enlaces desconocidos, evitar enlaces con temas de ubicación enviados por mensajes o redes sociales y revisar el navegador antes de aprobar acceso. En teléfonos, conviene revisar periódicamente qué sitios tienen permisos guardados.

Si se aprobó un permiso sospechoso, se debe revocar el permiso del sitio, limpiar datos del sitio, cerrar la pestaña y evitar volver a interactuar con la página. También conviene mantener el navegador y el sistema operativo actualizados, preferir aplicaciones oficiales y dominios conocidos, y desactivar la ubicación precisa cuando no sea necesaria.

8. Consideración ética

Este estudio se realizó estrictamente con fines educativos y analíticos. El sitio, el túnel, la sesión de terminal y el teléfono fueron operados por el investigador en un escenario acotado. La lección defensiva es clara: los permisos del navegador no son ventanas emergentes sin importancia. Son decisiones de confianza.

La conclusión es directa: cuando un sitio pide ubicación, el hábito más seguro es pausar, verificar el origen y negar la solicitud a menos que la necesidad sea legítima y esperada.